

CloudTrail 관측 공백 환경에서 AWS 인프라 상태 변화 기반 그래프 추적 모델

강인석¹ 서장훈² 정준식³ 박기웅[‡]

¹창원대학교 (학부생), ²홍익대학교 (학부생)

³연세대학교 (학부생), [‡]세종대학교 (교수)

A Graph-Based Tracking Model for AWS Infrastructure State Changes under Cloudtrail Observation Gaps

In-Seok Kang¹ Jang-Hoon Seo² Jun-Sik Jeong³ Ki-Woong Park[‡]

¹Changwon University (Undergraduate student)

²Hongik University (Undergraduate student)

³Yonsei University (Undergraduate student)

[‡]Sejong University (Professor)

요 약

클라우드 환경에서 발생하는 침해사고 조사는 API 호출 기록인 CloudTrail 로그에 크게 의존한다. 그러나 공격자가 로그 기록을 중지하거나 삭제하는 안티포렌식(Anti-forensics) 행위를 수행할 경우, 조사자는 행위 기록이 전무한 관측 공백(Observation Gap)에 직면하게 된다. 본 연구는 이러한 원본 로그 의존적 조사의 한계를 극복하기 위해, 인프라의 과거와 현재 상태 차이(ΔS)를 분석하여 다단계 침해 행위를 역추적하는 그래프 기반 추적 모델을 제안한다. 제안 모델은 외부의 격리된 보안 계층에서 다중 도메인 수집기를 통해 AWS 제어 평면의 위변조 불가능한 고유 메타데이터 스냅샷을 확보한다. 이후 추출된 리소스 상태 변화 데이터를 바탕으로 구조적 종속성과 시간적 인접성을 분석하여 흩어진 변경 사항들을 방향성 비순환 그래프(DAG)로 연결한다. Stratus Red Team을 이용한 다단계 공격 에뮬레이션 실험 결과, 제안 모델은 원본 로그 없이도 백도어 계정 생성부터 S3 버킷 정책 변조로 이어지는 인과 관계를 성공적으로 식별하였으며, 환경 내 발생하는 무관한 정상 상태 변화를 효과적으로 고립시켰다. 본 연구는 저비용 상태 비교 아키텍처를 통해 클라우드 환경의 선제적 포렌식 레디니스(Forensic Readiness)를 확보하는 실효성 있는 대안을 제시한다.

I. 서론

AWS와 같은 동적 클라우드 환경에서 침해 사고가 발생할 경우, 공격자의 초기 침투 경로, 권한 상승, 그리고 리소스 변조 행위를 파악하기 위해 API 호출 내역이 기록된 CloudTrail 로그가 핵심적인 증거로 활용된다. 하지만 공격자가 안티포렌식(anti-forensics)의 일환으로 StopLogging API를 호출하여 로그 기록을 중지시키거나 저장소인 S3 버킷의 접근 권한을 훼손할 경우, 조사자는 행위 기록이 전무한 관측 공백(observation gap) 상황에 직면하게 된다. 기존의 클라우드 침해 사고 조사 기법은 주로 대용량으로 수집된 원본 로그를 기계학습이나 통계적 기법으로 분석하는 데 치중되어 있어, 이처럼 원본 로그 자체가 소실된 상황에서는 뚜렷한 대안을 제시하지 못한다. 이에 본 연구는 로그가 부재한 시간 구간에 대해, 인프라의 과거 상태(S_{before})와 현재

상태(S_{after})의 차이(ΔS)를 계산하여 환경의 변화 여부를 추적하는 방법론을 제안한다. 이를 통해 로그 없이도 AWS 인프라에 남겨진 리소스 변조 흔적을 그래프 기반으로 구조화하여 조사자에게 직관적인 행위 궤적을 제공하는 것을 목적으로 한다.

II. 기존 기술과의 차별성

본 연구가 제안하는 모델은 로그가 아닌 인프라 상태의 시점 간 차이(ΔS)를 포렌식 근거로 삼아 파편화된 변조 행위들을 그래프로 재구성한다는 점에서, 아래 세 가지 측면에서 기존의 인프라 상태 관리 도구 및 클라우드 보안 가시성 기술과 목적과 동작 방식이 뚜렷하게 구분된다.

2.1 안티 포렌식 상황에서의 우회 추적

기존 클라우드 포렌식은 로그 원본에 의존하므로

관측 공백 발생 시 추적이 단절된다. 반면 본 연구는 로그가 아닌 클라우드 환경 자체에 남겨진 상태의 차이를 포렌식 아티팩트로 활용하여 최종 결과물을 역추적한다.

2.2 구성 편차 탐지의 한계 극복

AWS Config 등의 기존 도구는 공격자에 의해 구성 기록기가 중지되면 동일한 관측 공백이 발생한다. 제안 모델은 내부 로깅 서비스에 의존하지 않고 외부에서 AWS SDK를 통해 독립적인 스냅샷을 수집하므로 사각지대를 극복한다.

2.3 위변조 불가능한 고유 메타데이터 기반의 무결성 확보

본 연구가 스냅샷 비교의 기준(anchor)으로 삼는 데이터는 로그 계층이 아닌, AWS 제어 평면(control plane)이 리소스 생성 시점에 발급하는 고유 메타데이터(InstanceId, CreationDate, ARN 등)이다. 공격자는 리소스를 생성·삭제할 수는 있어도, AWS가 부여한 고유 식별값과 생성 시각을 소급하여 위조할 수는 없으므로 상태 비교(ΔS)의 무결성을 보장한다. 예를 들어 공격자가 특정 IAM 역할을 삭제한 뒤 동일한 이름과 권한으로 재생성 하더라도, 신규 리소스는 이전과 다른 ARN 발급 시각(CreationDate) 및 내부 식별값을 부여받으므로 REMOVED와 ADDED가 각각 별도의 이벤트로 기록되어 은폐 시도 자체가 오히려 탐지 단서가 된다.

2.4 기존 연구와의 비교 요약

표1. 기존 접근법과 제안 모델 비교

구분	CloudTrail	AWS Config	제안 모델
근거 데이터	API 호출	구성 이력	리소스 스냅샷
기록 주체	내부 로깅 서비스	내부 기록기	외부 격리 수집기
무력화 (공백 발생)	O (로깅 중지)	O (기록기 중지)	X (권한 분리)

III. 상태 변화 기반 그래프 추적 모델

본 제안 시스템은 다중 도메인 수집기, 상태 차이 분석, 그래프 모델링이라는 세 가지 핵심 단계로 구성된다.

3.1 다중 도메인 수집기 및 스냅샷 확보 방안

로그가 사라진 상황에서 조사자가 참고할 수 있는 것은 현재 인프라의 파편화된 단면이다. 본 연구는 침해 사고와 직결되는 5개 핵심 영역(IAM, Security Group, EC2, S3, VPC)을 하나의 수집기로 통합하여 동일한 시점 기준으로 나란히 확보한다. 특정 시점의 스냅샷은 타겟 인프라 내부에 수집기를 두는 것이 아니라, 물리적·논리적으로 분리된 격리된 보안 계정(Security Account)에서 교차 계정 역할(Cross-AccountRole)을 부여받아 AWS SDK(Boto3)의 상태 조회 API(D

escribe*, List*)를 주기적으로 호출하는 방식으로 확보한다. 이러한 아키텍처는 공격자가 타겟 계정의 권한을 탈취하여 내부 로깅 시스템을 중지(StopLogging) 시키더라도, 외부 보안 계정에서 구동되는 수집기의 스냅샷 수집 동작 자체는 무력화할 수 없다는 구조적 안전성을 제공한다.

표2. Boto3 기반 AWS 인프라 리소스 수집 대상

대상 서비스	주요 수집 항목	분석 활용
IAM	• User, Role, Policy 등 권한 및 계정 구성 정보	• 악의적 사용자 생성 • 권한 상승 탐지
Security Group	• Group ID/Name • Inbound/Outbound 규칙	• 접근 제어 변경 추적
EC2	• 인스턴스 존재 여부 • 네트워크 인터페이스 구성 정보	• 비인기 컴퓨팅 자원 생성 • 인스턴스 변경 식별
S3	• Bucket Name/ARN • Public Policy • Versioning	• 데이터 유출/훼손 관련 설정 변조 확인
VPC	• Network ACL 식별자 및 연결 상태	• 네트워크 라우팅 경로 변경 • ACL 규칙 변경 탐지

3.2 상태 차이 분석

서로 다른 시점에 확보한 침해 사고 발생 전후의 스냅샷을 대조하여, 새로 생긴 리소스(ADDED), 사라진 리소스(REMOVED), 속성이 바뀐 리소스(MODIFIED)를 구분한다. 5개 영역을 개별적으로 보지 않고 하나의 스냅샷 안에서 대조함으로써, IAM 영역의 역할 추가와 Security Group의 규칙 변경이 동일한 침입 시도의 흔적일 수 있다는 가설을 도출한다.

3.3 그래프 모델링

도출된 변경 목록을 단순한 리스트로 나열하면 서로 독립된 사건처럼 보인다. 본 연구가 개별 리소스의 변화 자체가 아닌 변화 간의 관계(Relation)를 시각화하는 이유는, 실제 침해 사고가 단일 이벤트가 아닌 연속된 인과적 흐름으로 발생하기 때문이다. 로그가 부재한 상황에서 본 모델은 두 가지 기준을 통해 엣지(Edge)를 생성한다.

첫째는 리소스 메타데이터 내에 명시된 식별자 정보를 활용한 구조적 종속성(Structural Dependency)이다. 예를 들어, Access Key 리소스의 메타데이터에 포함된 소유 사용자(Owner User) 정보를 참조하여 해당 IAM User와 Access Key 노드를 엣지로 연결한다. 이와 같은 방식으로 EC2 인스턴스의 네트워크 속성에 명시된 보안 그룹(Security Group) ID를 확인해 인스턴스와 보안 그룹을 연결하거나, IAM Role 메타데이터 내의 연결 정책(Attached Policies) 리스트를 기반으로 Role과 Policy 간의 관계를 구성하는 등 리소스가 본질적으로 지니는 종속성을 시각화한다.

둘째는 스냅샷 수집 주기 내에서 발생한 리소스 추가(ADDED)와 변조(MODIFIED) 간의 시간적

인접성(Temporal Proximity)이다.

예를 들어 [IAM 권한 생성] → [S3 버킷 정책 변조] → [외부 계정 접근 허용]으로 이어지는 공격 경로에서, 개별 리소스 변화만 시각화할 경우 '누가 어떤 경로로 접근하여 영향을 미쳤는가'를 추론하기 어렵다. 하지만 변경된 시간대가 극히 인접한 리소스들을 노드(Node)로 묶고, 앞서 언급한 메타데이터 기반의 구조적 종속성을 바탕으로 이들 간의 의존성을 엮기로 연결하면, 흩어진 변경 사항들이 비로소 단순한 상태 이상을 넘어 단일 침해 사고 내에서 발생한 다단계 이상 행위의 연관성으로 명확히 식별된다.

IV. PoC 기반 실험 및 가능성 검증

제안 모델의 실효성을 확인하기 위해 오픈소스 클라우드 공격 에뮬레이션 도구인 Stratus Red Team을 활용하여 통제된 PoC(Proof of Concept) 실험을 수행하였다. 본 실험은 정밀한 통계적 검증보다는, 로그 부재 상황에서 상태 변화만으로 다단계 공격의 흐름을 재구성할 수 있는지 그 기술적 가능성을 확인하는 데 초점을 맞추었다.

4.1 시나리오 개요

실험은 지속성 확보(백도어 IAM 유저 생성) 및 정보 유출 통로 구축(S3 버킷 정책 변조를 통한 외부 접근 허용) 시나리오로 진행되었다. 5대 서비스별 메타데이터 상태 변화 내역은 다음과 같이 수집되었다.

표3. 시나리오 서비스별 메타데이터 변화 요약

구분	상태 변화	주요 행위
IAM	리소스 추가	• 활성 상태의 액세스 키 발급
Security Group	속성 갱신	• 보안 그룹의 메타데이터 변경 • (vpc_id 및 group_id 변경)
S3	정책 추가	• S3 버킷에 타 계정의 객체 접근 허용 정책
VPC	리소스 추가 및 갱신	• 신규 VPC 1개 및 하위 네트워크 데이터 추가 • 기존 VPC 1개와 연관 자원의 removed와 added 동시 기록
EC2	변화 없음	-

4.2 그래프 시각화 및 행위 연관성 식별 고찰

수집된 상태 차이를 그래프 데이터베이스 플랫폼인 Neo4j를 활용하여 모델링 하였다. 이때 3.3 절에서 정의한 노드 간의 연결 기준이 직접적으로 적용되었다. 즉, 변경 발생 시점이 비슷한 리소스들을 시간적 인접성을 기준으로 묶고, 변경된 S3 버킷 정책 정보 안에 새로 생성된 백도어 IAM 계정에 대한 참조가 포함되어 있는 것을 단서로 삼아 구조적 종속성 엮기를 생성한 것이다. 그 결과, 구성된 그래프는 대략적으로 다음과 같은 형태를 띤다.

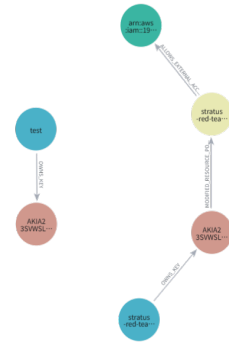


그림 1 스냅샷 상태 차이 데이터 기반 다단계 침해 행위 연관성 식별 결과

단순히 IAM 계정이 생기고 S3 정책이 바뀌었다는 개별 사실을 넘어, 새롭게 생성된 백도어 계정이 타겟 S3 버킷의 접근 제어를 느슨하게 만드는 데 사용되었다는 연결 고리가 시각적으로 뚜렷하게 드러났다. 특히 주목할 점은, 시나리오 실행 과정에서 부수적으로 발생한 VPC 및 Security Group의 속성 갱신 내역([표 3] 참조)과 무관한 정상 계정 생성 행위 등은 침해 궤적과 인과 관계를 맺지 못하고 독립된 노드로 분리되었다는 것이다. 이를 통해 본 제안 모델이 다중 영역에서 동시다발적으로 발생하는 상태 변화(노이즈) 속에서도, 로그 한 줄 없이 실제 초기 침투와 데이터 유출 준비 단계 간의 유의미한 인과관계만을 효과적으로 식별하고 고립시킬 수 있음을 입증하였다.

V. 실무 환경 적용을 위한 비용 효율성 및 시스템 확장 방안

본 연구에서 제안한 모델은 단순 상태 조회 API만을 사용하므로, 대규모 인프라 환경에서 지속적으로 구동하더라도 수집 및 보관 비용 부담이 적다. 해시(hash) 기반 대조 방식을 결합하여 해시 불일치가 탐지된 실제 변경 리소스의 상태 정보만 선별적으로 저장한다면 스토리지 사용량을 획기적으로 절감할 수 있다. 이러한 저비용·초경량화 개념은 향후 AWS Lambda와 Amazon EventBridge를 연동한 주기적 스냅샷 자동 수집 파이프라인으로 구체화될 수 있으며, 이를 통해 관측 공백의 시간 범위를 수집 주기(예: 1시간) 단위로 단축하여 포렌식 레디니스(forensic readiness)를 구현할 수 있다.

VI. 결론

본 연구는 클라우드 내 관측 공백 극복을 위해, 원본 로그에 의존하지 않는 상태 변화 기반의 그래프 추적 모델을 제안하여 실효성 있는 침해사고 대응 대안을 제시하였다.

다만 본 모델은 두 가지 주요 한계점을 갖는다. 첫째, 리소스 상태 변조가 없는 단순 읽기(GetObject) 기반의 데이터 유출은 식별할 수 없다.

둘째, 다중 영역에 대한 순차적 API 호출 방식에 기인하여 스냅샷 간 시점 정합성 불일치 및 오탐이 발생할 수 있다.

이러한 사각지대를 보완하기 위해 향후 VPC Flow Logs나 GuardDuty 등의 이상 탐지 알럿을 결합하는 하이브리드 추적 연구가 병행되어야 한다. 이때 본 제안 모델의 핵심인 외부 독립 수집 원칙을 유지하기 위해, 내부 관리형 서비스의 알럿을 격리된 별도의 보안 계정으로 전달받아 그래프 노드에 매핑하는 안전한 연동 설계가 요구된다. 아울러 다양한 공격 시나리오에 대한 추가 PoC 검증을 통해 모델의 일반화 가능성을 확보할 계획이다.

[ACKNOWLEDGEMENT]

본 논문은 과학기술정보통신부 및 한국정보보호산업협회의 융합보안 인력양성사업(ICT융합산업보안)으로부터 지원받은 연구임.

[참고문헌]

[1] Zawoad, Shams, and Ragib Hasan. "Cloud Forensics." Encyclopedia of Cloud Computing (2016): 233-244.

[2] Amazon Web Services, "AWS CloudTrail User Guide," AWS Documentation.

[3] Amazon Web Services, "AWS Config Developer Guide," AWS Documentation.

[4] DataDog, "Stratus Red Team: Cloud Attacker Emulation," GitHub Repository, <https://github.com/DataDog/stratus-red-team>

[5] Neo4j, "Neo4j Graph Data Platform,"

[6] Boto3, "AWS SDK for Python (Boto3) Documentation,"